

Grok Build CLI

代码数据上传与“偷代码”争议

客观综述：舆论线索区分 · 技术事实 · 时间线 · 信任影响 · 补救与现状

整理日期 2026-07-18

涉及产品 xAI / SpaceXAI · Grok Build CLI (终端 coding agent)

参考时点 约 2026-07-11 至 2026-07-18 公开报道与社区复测

报告性质 公开信息二次整理 (非官方、非审计、非法务)

目录

- 01 执行摘要
- 02 三条舆论线索 (严格区分)
- 03 技术事实：发生了什么
- 04 时间线
- 05 信任冲击分析
- 06 公开补救措施
- 07 现状：现在还会不会整库上传
- 08 开发者务实建议
- 09 结论
- 10 来源与局限

说明：本文档区分「产品形态相似/兼容争议」「商业秘密诉讼」「整库数据上传争议」三条线索，重点展开第三条。事实以独立研究者抓包与主流媒体报道为准；公司回应以公开社媒与高管声明为准。未经第三方审计的承诺，一律标注为「声明/承诺」。

01 执行摘要

整库上传通道

已关闭

server-side flag

任务相关读文件

仍会上传

云端 agent 常态

历史数据删除

公开承诺

未经第三方审计

一句话结论

2026 年 7 月上旬，Grok Build CLI 被证实会在默认情况下把完整 Git 仓库（含提交历史）打成 bundle 上传至 xAI 侧云存储；约 7 月 13 日服务端关闭该通道。这是数据边界事故，不是“抄竞品源码”的判决。

独立研究者 cereblab 用 mitmproxy 分析 Grok Build v0.2.93 发现：工具除模型对话通道外，另有存储通道将 tracked 仓库 + 完整 commit 历史上传至 Google Cloud Storage（报道桶名如 grok-code-session-traces）。该行为与是否打开具体文件、是否关闭「Improve the model」基本解耦。

同类云端 coding agent 通常只发送任务相关文件；整库 scoop 是 Grok 事发时的 outlier。约 2026-07-13 后，disable_codebase_upload: true 使整库上传在多次复测中停止；xAI 说明 ZDR 与 /privacy，Musk 承诺删除历史上传数据，随后客户端开源。截至整理日：整库通道关闭；任务文件仍进模型请求。

02 三条舆论线索（需严格区分）

2.1 线索一：产品形态相似 / 「抄 Claude Code」

背景：2026-03 末 Claude Code 因 source map 源码暴露；2026-05 中 Grok Build 上线，兼容 ~/.claude/skills/、AGENTS.md、hooks、MCP 等。社区出现「抄 Claude / 仿 Cursor」说法。

判断：行业 agent 范式趋同 + 兼容迁移 ≠ 拷贝闭源仓库。公开信息未见法院认定「Grok Build = 抄 Anthropic 源码」。属产品竞争舆论，非本报告技术主线。

2.2 线索二：xAI 作为原告的商业秘密诉讼（方向相反）

背景：约 2025-08 ~ 09，公开报道 xAI 起诉前员工 Xuechen Li 及/或 OpenAI，称带走 Grok 相关机密。2026-02 与 06，媒体报道法官 Rita Lin 驳回对 OpenAI 的 trade-secret 主张（证据门槛等）。

判断：叙事方向是「xAI 称自己被偷」，不是「Grok 偷用户代码」。与线索三不可混谈。

2.3 线索三：整库数据上传（本报告主线）

性质：用户本地代码（含 git 历史）被超出任务合理范围地上传至 xAI 存储。属数据边界与隐私预期问题，不是 IP 抄袭判决。下文全部围绕此线索。

线索	核心争议	方向	本报告权重
产品相似 / 兼容 Claude	是否抄竞品实现	舆论评价	低（澄清）
xAI v. 前员工 / OpenAI	商业秘密是否被带走	xAI 为原告	低（澄清）
整库上传 GCS	默认数据边界是否失控	用户数据 → xAI	高（主线）

表 1 三条线索对照

03 技术事实：发生了什么

3.1 产品语境

Grok Build 是本地终端 AI 编程助手。云端模型要干活，通常需要接收任务相关源文件——这是行业常态。合理预期是「按需读取」，不是默认批量转移整个仓库历史。

3.2 独立研究结论 (cereblab 等)

公开证据要点 (综合 THN、The Register、gist / 复现仓库等)：

- 测试对象：Grok Build CLI v0.2.93 (事发分析版本)。
- 方法：mitmproxy 线级抓包；可从拦截流量还原 Git bundle 并 clone。
- 行为：tracked 仓库打成 Git bundle (含完整 commit 历史) 上传。
- 通道：与模型对话分离的存储通道 (报道出现 /v1/storage 等)。
- 目的地：xAI 使用的 GCS 桶 (报道名 grok-code-session-traces 等)。
- 解耦性：即使用户要求「不要读取任何文件」，整库上传仍可发生。
- canary：未打开的探测文件可从捕获的 bundle 原样恢复。
- 量级：约 12 GB 仓库场景，模型流量约 192 KB，存储通道约 5.1 GiB (约 2.7 万倍)。
- 密钥：实际读到的 .env 可明文进模型请求；git 历史中的旧 secret 可随 bundle 出境。
- 对比：Claude Code / Codex 等未见同等默认整库 bundle 行为。

3.3 两条通道必须分开

通道	内容	行业惯例	事发争议点
任务 / 模型通道	agent 为任务读取的文件	云端工具通常需要	敏感文件明文、缺脱敏
整库存储通道	Git bundle：全库 + 历史	远超「按需打开」预期	默认开启、与用户指令解耦

表 2 数据通道区分

3.4 用户控制项为何失效

控制项语义错位

「用于改进模型」(Improve the model) 管的是训练同意，不是「禁止代码离机」。关闭后整库仍可上传——用户获得虚假安全感。训练同意 ≠ 同步/追踪关闭。

3.5 证据边界 (客观限定)

抓包足以支持：传输发生、服务端接受、内容可还原为仓库历史。一般不直接证明：是否训练、员工是否浏览、.gitignore 未跟踪文件是否一律纳入 (报道重点是 tracked + history)。社区「家目录大范围上传」个案会放大恐慌，应与 git bundle 主线证据分开记录。

04 时间线 (公开信息)

时间 (约)	事件
2026-03 末	Claude Code source map 泄露 (行业背景，非直接原因)
2026-05 中	Grok Build 上线；兼容 Claude 配置生态
2026-07-11 前后	cereblab 公开 mitmproxy 分析与证据 (v0.2.93)

时间（约）	事件
2026-07-12 ~ 13	媒体与社区发酵；跨工具对比称 Grok 为 outlier
2026-07-13	服务端 disable_codebase_upload；整库上传复测停止
2026-07-13	ZDR / /privacy 说明；Musk 承诺删除历史上传数据
2026-07-14 ~	The Register、THN 等报道止血与承诺
2026-07-15 前后	Grok Build 相关客户端开源（Apache 2.0 等口径）
2026-07-18	本报告整理；本地示例 CLI 版本可见 0.2.103

表 3 事件时间线

05 信任冲击分析

伤害不只在「云端 AI 会看到代码」（开发者本有预期），而在默认边界、控制语义与沟通方式的叠加：

- 默认范围过大：预期按任务读文件，实际整库 + 历史。
- 与用户指令脱节：禁止读文件仍可整库上传 → 属产品/后台设计。
- 控制项误导：关「改进模型」仍上传 → 虚假安全感。
- 历史密钥复燃：曾提交后删除的 secret 仍可能出境。
- 竞品对比放大：同类工具中成为 outlier。
- 响应形态：先被抓包、后静默关 flag；正式安全通告相对不足。

06 xAI / 官方公开补救措施

6.1 技术止血

约 2026-07-13，同一客户端版本下服务端下发 disable_codebase_upload: true 等；多次复测未见 /v1/storage 整库上传。多账号一致，属服务端全局关闭。

6.2 产品与政策口径

公开说明大意：企业 ZDR 不保留 trace/code；API key 尊重 ZDR；非 ZDR 用户可用 /privacy 关闭保留并删除已同步数据。研究者批评：真正关掉整库上传的是全局 flag，/privacy 不宜被说成「修好整库上传的按钮」。

6.3 高管删除承诺

公开承诺（非审计结论）

Elon Musk 约 2026-07-13 表示：此前上传数据将 completely and utterly deleted。媒体注明无法独立核实。本文标注为「公开承诺」。

6.4 开源客户端

随后相关代码开源（报道 Apache 2.0 等）。提升客户端可审计性；不等于服务端策略透明。上传逻辑若仍在代码中仅靠远端 flag 关闭，理论上可再启用。

6.5 仍不充分的问题

- 默认整库上传的产品动机是什么？
- 保留期限、访问控制、内部审计？
- 受影响用户数与仓库范围？
- 是否有正式 security advisory？
- 历史数据删除的可核验证明？

补救项	公开状态	信任评价
关闭整库上传	服务端 flag；复测停止	止血有效、较快
/privacy 与 ZDR	社媒与产品路径	有用但语义易混淆
删除历史上传	高管公开承诺	承诺有、审计无
开源 CLI	公开仓库报道	提升客户端可审计性
动机与影响面	相对不足	信任闭环未完成

表 4 补救措施评估

07 现状：现在还会不会「偷」

精确表述

事发时：干不干活都可能整库打包上传。当前公开状态：整库通道已关；任务相关内容仍会按需进入模型通道。说「现在还在偷整库」与公开证据不符；说「数据完全不出境」同样不准确。

行为	截至公开信息	备注
整库 + git 历史默认打包上传	已关闭 (server-side)	无新公开抓包证明重开
为任务读文件并送入模型	仍会发生	云端 coding agent 常态
关「改进模型」= 永不离机	错误理解	该开关 ≠ 本地-only
上传代码是否仍在客户端	可能仍在、靠 flag 关	开源审计关注点

表 5 当前行为状态

08 开发者务实建议

1. 若在约 2026-07-13 前对敏感仓库运行过 Grok Build：将 tracked 内容与 git 历史视为可能曾出境；轮换密钥/token，尤其「提交后又删除」的历史 secret。
2. CLI 中运行 /privacy 查看与调整保留策略（补充动作，不是当初阻止整库上传的主开关）。
3. 勿在家目录、密码库目录直接启动 agent。
4. 敏感项目：密钥只放密钥管理器或未进 git 的环境；工作区保持干净。
5. 企业场景：确认 ZDR / 合同数据条款。
6. 需自证时：抓包观察是否仍有大体积 storage 上传；结合开源审计 upload 模块。
7. 个人低敏感仓库：按自身威胁模型决定是否继续使用。

09 结论

这是一次有线级复现证据的数据边界事故：默认收集范围显著超过合理预期，隐私控制语义未能覆盖该行为。披露后服务端较快止血，并辅以 ZDR、/privacy、删除承诺与开源。技术止血降低了「持续整库 scoop」风险，但动机说明、影响面与删除可核验性仍不足以完全修复专业用户信任。

勿与「抄 Claude 源码」「xAI 商业秘密诉讼」混为一谈。普通个人仓库的剩余风险接近其他云端 AI 编程工具；高敏感闭源库应额外关注远端策略是否可再变更，以及合同 / ZDR 是否匹配合规要求。

10 来源与局限

10.1 主要来源类型

- cereblab 抓包分析、gist 与复现仓库（含跨工具对比）。
- 媒体：The Hacker News、The Register、The Verge、Cybernews 等（2026-07 中旬）。
- 社媒：@SpaceXAI、相关工程人员、Elon Musk 关于删除与隐私的声明。
- 社区二次分析：开源发布、客户端仍含 upload 路径等。
- 平行背景：Claude Code 泄露、xAI-OpenAI 诉讼公开报道（仅作线索区分）。

10.2 局限

- 公开信息二次整理，非 xAI 内部调查，非法务/渗透结论。
- 「当前已关闭」依据公开复测与报道，不能排除个体差异或后续策略变更。
- 删除承诺无法由本文独立审计。
- 版本演进快（事发 0.2.93，其后更高版本），行为以当时测试与服务端策略为准。

—— 报告正文结束 —— 如需核对原始证据，请优先阅读研究者公开 gist / 复现仓库，以及 The Hacker News、The Register 等 2026-07-14 前后专题报道。